Luca Danisi **30-4-2026**

Analisi di rete

1 - 🎯 Obiettivo :

Lo scopo di questo laboratorio è analizzare una cattura di traffico di rete effettuata con Wireshark, al fine di identificare eventuali Indicatori di Compromissione (IOC), ovvero segnali che indicano che un attacco è in corso o è già avvenuto.

A partire dagli IOC trovati, verranno formulate ipotesi sui possibili vettori di attacco utilizzati, e verranno proposte azioni concrete per ridurre l'impatto dell'attacco.

🧪 **Laboratorio**

🐉 **Kali Linux**: su Virtual Box (192.168.50.100)

Macchine su su rete interna

2 - Strumenti utilizzati :

Wireshark — strumento di analisi del traffico di rete. Permette di catturare e ispezionare i pacchetti che transitano sulla rete, visualizzando protocolli, indirizzi IP e contenuto delle comunicazioni.

3 – Risultati:

IOC #1 — ✅ Alla riga 1 si osserva un pacchetto broadcast inviato da `192.168.200.150` verso `192.168.200.255` tramite protocollo BROWSER, in cui la macchina si auto-identifica con il nome METASPLOITABLE, annunciando pubblicamente i servizi esposti sulla rete.

IOC #2 — ✅ **Port Scan attivo** Dalla riga 13 in poi si osserva un volume elevatissimo di pacchetti TCP con flag SYN provenienti da 192.168.200.100 verso

192.168.200.150, su porte diverse e in sequenza rapidissima. Questo pattern è compatibile con una scansione attiva delle porte della macchina target.

IOC #3 — ✅ Servizio Samba vulnerabile esposto Filtrando il traffico con smb, si osserva che la macchina 192.168.200.150 sta trasmettendo in broadcast la propria versione di Samba: **Samba 3.0.20-Debian**. Questa versione è nota per contenere vulnerabilità critiche che permettono l'esecuzione di comandi remoti senza autenticazione (CVE-2007-2447).

4 – Ipotesi sui vettori di attacco :

Sulla base degli IOC identificati, è possibile formulare le seguenti ipotesi:

Ipotesi 1 — Reconnaissance attiva Il traffico SYN osservato nella cattura suggerisce che l'attaccante (192.168.200.100) abbia eseguito una scansione attiva della rete per mappare i servizi esposti sulla macchina target (192.168.200.150). Non è possibile determinare con certezza lo strumento utilizzato dalla sola analisi del traffico, tuttavia il pattern osservato è compatibile con tool di port scanning come Nmap.

Ipotesi 2 — Sfruttamento di Samba 3.0.20 La presenza di Samba 3.0.20 esposto sulla rete rappresenta un vettore di attacco critico. Questa versione è affetta dalla vulnerabilità **CVE-2007-2447**, che consente a un attaccante non autenticato di eseguire comandi arbitrari sulla macchina remota. È ragionevole ipotizzare che l'attaccante, dopo aver identificato la versione tramite il port scan, possa sfruttare questa vulnerabilità per ottenere accesso al sistema.

5 - Conclusioni :

L'analisi della cattura Wireshark ha evidenziato segnali chiari di una attività di ricognizione attiva sulla rete, con un attaccante che ha mappato i servizi esposti sulla macchina target e identificato un servizio critico e vulnerabile come Samba 3.0.20. La vulnerabilità identificata permette l'accesso completo al sistema senza autenticazione. Si raccomanda di intervenire immediatamente sulle azioni indicate per ridurre la superficie di attacco.

Svolgimento Tecnico

Target 1:

Step 1 – Analisi generale del traffico

Al primo sguardo della cattura, si osserva immediatamente un volume anomalo di pacchetti TCP provenienti da 192.168.200.100 verso 192.168.200.150. Il traffico si presenta in modo molto regolare e meccanico, con pacchetti SYN inviati su porte sempre diverse in rapidissima sequenza, caratteristica tipica di una scansione automatizzata.

Step 2 – Analisi del traffico SYN

Osservando le righe dalla 13 in poi, si nota che i pacchetti TCP hanno quasi tutti il flag SYN attivo e provengono sempre dallo stesso IP sorgente. Questo pattern è compatibile con un port scan attivo, in cui l'attaccante tenta di identificare quali porte sono aperte sulla macchina target.

Step 3 – Analisi del traffico broadcast

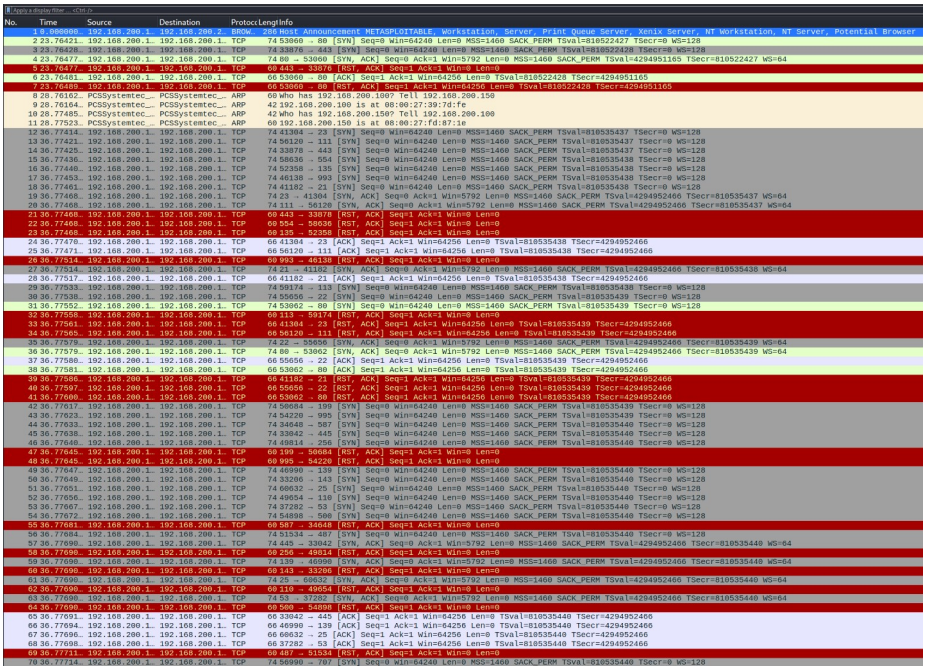
Alla riga 1 si osserva un pacchetto di tipo BROWSER inviato in broadcast da 192.168.200.150 verso 192.168.200.255, in cui la macchina si auto-identifica pubblicamente con il nome METASPLOITABLE e annuncia i propri servizi.

Step 4 – Filtro smb

Applicando il filtro `smb` nella barra di Wireshark, è stato possibile isolare il traffico SMB e analizzare nel dettaglio il pacchetto di Host Announcement. Dal pannello dei dettagli si legge chiaramente che la macchina sta girando **Samba 3.0.20-Debian**, versione affetta da vulnerabilità critiche note.

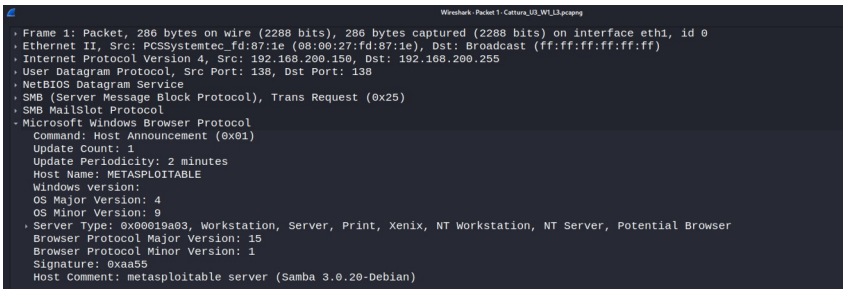
Screenshot

Figure 1 – Analisi generale traffico.



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000…	192.168.200.1…	192.168.200.2…	BROW…	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential Browser
2	23.76421…	192.168.200.1…	192.168.200.1…	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23.76428…	192.168.200.1…	192.168.200.1…	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4	23.76477…	192.168.200.1…	192.168.200.1…	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23.76477…	192.168.200.1…	192.168.200.1…	TCP	66	443 → 33878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.76481…	192.168.200.1…	192.168.200.1…	TCP	66	53060 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.76489…	192.168.200.1…	192.168.200.1…	TCP	66	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8	28.76162…	PCSSystemtec_…	PCSSystemtec_…	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.76164…	PCSSystemtec_…	PCSSystemtec_…	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.77485…	PCSSystemtec_…	PCSSystemtec_…	ARP	42	Who has 192.168.200.150? Tell 192.168.200.100
11	28.77523…	PCSSystemtec_…	PCSSystemtec_…	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.77414…	192.168.200.1…	192.168.200.1…	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.77421…	192.168.200.1…	192.168.200.1…	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.77425…	192.168.200.1…	192.168.200.1…	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.77436…	192.168.200.1…	192.168.200.1…	TCP	74	58636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.77440…	192.168.200.1…	192.168.200.1…	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.77453…	192.168.200.1…	192.168.200.1…	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.77461…	192.168.200.1…	192.168.200.1…	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36.77468…	192.168.200.1…	192.168.200.1…	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.77468…	192.168.200.1…	192.168.200.1…	TCP	74	111 → 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36.77468…	192.168.200.1…	192.168.200.1…	TCP	60	443 → 33878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.77468…	192.168.200.1…	192.168.200.1…	TCP	60	554 → 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.77468…	192.168.200.1…	192.168.200.1…	TCP	60	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.77470…	192.168.200.1…	192.168.200.1…	TCP	66	41304 → 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.77471…	192.168.200.1…	192.168.200.1…	TCP	66	56120 → 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.77514…	192.168.200.1…	192.168.200.1…	TCP	60	993 → 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36.77514…	192.168.200.1…	192.168.200.1…	TCP	74	21 → 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36.77517…	192.168.200.1…	192.168.200.1…	TCP	66	41182 → 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.77533…	192.168.200.1…	192.168.200.1…	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36.77539…	192.168.200.1…	192.168.200.1…	TCP	74	55656 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
31	36.77552…	192.168.200.1…	192.168.200.1…	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36.77558…	192.168.200.1…	192.168.200.1…	TCP	60	113 → 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.77561…	192.168.200.1…	192.168.200.1…	TCP	66	41304 → 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.77565…	192.168.200.1…	192.168.200.1…	TCP	66	56120 → 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36.77579…	192.168.200.1…	192.168.200.1…	TCP	74	22 → 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
36	36.77579…	192.168.200.1…	192.168.200.1…	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
37	36.77580…	192.168.200.1…	192.168.200.1…	TCP	66	55656 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.77581…	192.168.200.1…	192.168.200.1…	TCP	66	53062 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
39	36.77586…	192.168.200.1…	192.168.200.1…	TCP	66	41182 → 21 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
40	36.77597…	192.168.200.1…	192.168.200.1…	TCP	66	55656 → 22 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
41	36.77600…	192.168.200.1…	192.168.200.1…	TCP	66	53062 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
42	36.77617…	192.168.200.1…	192.168.200.1…	TCP	74	50664 → 199 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
43	36.77623…	192.168.200.1…	192.168.200.1…	TCP	74	54220 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
44	36.77633…	192.168.200.1…	192.168.200.1…	TCP	74	34648 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
45	36.77638…	192.168.200.1…	192.168.200.1…	TCP	74	33042 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
46	36.77640…	192.168.200.1…	192.168.200.1…	TCP	74	49814 → 256 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
47	36.77645…	192.168.200.1…	192.168.200.1…	TCP	60	199 → 50684 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
48	36.77645…	192.168.200.1…	192.168.200.1…	TCP	60	995 → 54220 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
49	36.77647…	192.168.200.1…	192.168.200.1…	TCP	74	46990 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
50	36.77649…	192.168.200.1…	192.168.200.1…	TCP	74	33206 → 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
51	36.77651…	192.168.200.1…	192.168.200.1…	TCP	74	60632 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
52	36.77656…	192.168.200.1…	192.168.200.1…	TCP	74	49654 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
53	36.77667…	192.168.200.1…	192.168.200.1…	TCP	74	37282 → 53 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
54	36.77672…	192.168.200.1…	192.168.200.1…	TCP	74	54898 → 500 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
55	36.77681…	192.168.200.1…	192.168.200.1…	TCP	60	587 → 34648 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
56	36.77684…	192.168.200.1…	192.168.200.1…	TCP	74	51534 → 487 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
57	36.77690…	192.168.200.1…	192.168.200.1…	TCP	74	445 → 33042 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
58	36.77690…	192.168.200.1…	192.168.200.1…	TCP	60	256 → 49814 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
59	36.77690…	192.168.200.1…	192.168.200.1…	TCP	74	139 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
60	36.77690…	192.168.200.1…	192.168.200.1…	TCP	60	143 → 33206 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
61	36.77690…	192.168.200.1…	192.168.200.1…	TCP	74	25 → 60632 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
62	36.77690…	192.168.200.1…	192.168.200.1…	TCP	60	110 → 49654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
63	36.77690…	192.168.200.1…	192.168.200.1…	TCP	74	53 → 37282 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
64	36.77690…	192.168.200.1…	192.168.200.1…	TCP	60	500 → 54898 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
65	36.77691…	192.168.200.1…	192.168.200.1…	TCP	66	33042 → 445 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
66	36.77694…	192.168.200.1…	192.168.200.1…	TCP	66	46990 → 139 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
67	36.77696…	192.168.200.1…	192.168.200.1…	TCP	66	60632 → 25 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
68	36.77698…	192.168.200.1…	192.168.200.1…	TCP	66	37282 → 53 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
69	36.77711…	192.168.200.1…	192.168.200.1…	TCP	60	487 → 51534 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
70	36.77714…	192.168.200.1…	192.168.200.1…	TCP	74	56990 → 707 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128

Figure 2 – Analisi broadcast

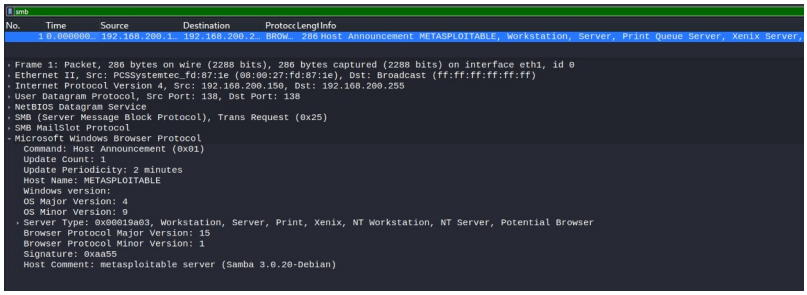


```
Wireshark · Packet 1 · Cattura_U3_W1_L3.pcapng
› Frame 1: Packet, 286 bytes on wire (2288 bits), 286 bytes captured (2288 bits) on interface eth1, id 0
› Ethernet II, Src: PCSSystemtec_fd:87:1e (08:00:27:fd:87:1e), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
› Internet Protocol Version 4, Src: 192.168.200.150, Dst: 192.168.200.255
› User Datagram Protocol, Src Port: 138, Dst Port: 138
› NetBIOS Datagram Service
› SMB (Server Message Block Protocol), Trans Request (0x25)
› SMB MailSlot Protocol
- Microsoft Windows Browser Protocol
    Command: Host Announcement (0x01)
    Update Count: 1
    Update Periodicity: 2 minutes
    Host Name: METASPLOITABLE
    Windows version:
    OS Major Version: 4
    OS Minor Version: 9
  › Server Type: 0x00019a03, Workstation, Server, Print, Xenix, NT Workstation, NT Server, Potential Browser
    Browser Protocol Major Version: 15
    Browser Protocol Minor Version: 1
    Signature: 0xaa55
    Host Comment: metasploitable server (Samba 3.0.20-Debian)
```

Figure 3 – Traffico Syn

12	36.77414…	192.168.200.1…	192.168.200.1…	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.77421…	192.168.200.1…	192.168.200.1…	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.77425…	192.168.200.1…	192.168.200.1…	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.77436…	192.168.200.1…	192.168.200.1…	TCP	74	58636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.77440…	192.168.200.1…	192.168.200.1…	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.77453…	192.168.200.1…	192.168.200.1…	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.77461…	192.168.200.1…	192.168.200.1…	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128

Figura 4 – Filtro SMB



```
smb
No.   Time          Source          Destination     Protoc Length Info
    1 0.000000…     192.168.200.1…  192.168.200.2…  BROW…  286    Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server,

› Frame 1: Packet, 286 bytes on wire (2288 bits), 286 bytes captured (2288 bits) on interface eth1, id 0
› Ethernet II, Src: PCSSystemtec_fd:87:1e (08:00:27:fd:87:1e), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
› Internet Protocol Version 4, Src: 192.168.200.150, Dst: 192.168.200.255
› User Datagram Protocol, Src Port: 138, Dst Port: 138
› NetBIOS Datagram Service
› SMB (Server Message Block Protocol), Trans Request (0x25)
› SMB MailSlot Protocol
- Microsoft Windows Browser Protocol
    Command: Host Announcement (0x01)
    Update Count: 1
    Update Periodicity: 2 minutes
    Host Name: METASPLOITABLE
    Windows version:
    OS Major Version: 4
    OS Minor Version: 9
  › Server Type: 0x00019a03, Workstation, Server, Print, Xenix, NT Workstation, NT Server, Potential Browser
    Browser Protocol Major Version: 15
    Browser Protocol Minor Version: 1
    Signature: 0xaa55
    Host Comment: metasploitable server (Samba 3.0.20-Debian)
```